

ФОРЕНЗИЧКИ ИЗВЕШТАЈ О САЈБЕР ИНЦИДЕНТУ

Analyst:	Немања Петровић
Organization:	ЦЕРТ-РС Крагујевац
Malware:	SQL Injection + Webshell
Threat Level:	HIGH
File Hash:	8277e0910d750195b448797616e091ad
Location:	Крагујевац

ОПИС ИНЦИДЕНТА:

Дана 12.01.2025. године детектован је неауторизован приступ веб апликацији Градске управе Крагујевац. Напад је извршен коришћењем SQL Injection технике на vulnerable login форми која није имала имплементиране prepared statements. Нападач је користио automated scanning tool (SQLMap) са IP адресе 198.12.67.143 (Канада).

Успешном експлоатацијом рањивости, нападач је добио приступ backend бази података и екстраховао креденцијале административних налога користећи UNION-based SQL injection. Након тога, uploadован је PHP webshell (c99.php) у директоријум /uploads/ који није имао ограничења типова фајлова. Webshell је коришћен за извршавање system команди, енумерацију датотека и покушај privilege escalation кроз kernel exploit.

Форензичка анализа Apache access логова показује да је нападач провео 3 сата и 27 минута истражујући систем, приступио осетљивим документима и креирао backdoor кориснички налог "sysadmin2". Идентификовано је укупно 847 malicious HTTP requests. Детектована је комуникација са Command & Control сервером на адреси 91.203.5.146 (Украјина). Систем је изван мреже, у току је процес remedijације укључујући patching SQL injection рањивости, измену свих лозинки и reimaging сервера.